

WEEK 6 – TASK 18 (EH)

CAPSTONE – FULL PENETRATION TEST AND PROFESSIONAL REPORT

Submitted By: MANOJ

Role: Cyber Security Intern

Internship Organisation: TechBiz Security

Internship ID: TBS-INT-2026-518

Submitted Date: 28 SEPT 2026

1. Executive Summary

This report documents a capstone penetration-testing exercise conducted against the intentionally vulnerable TryHackMe “Vulniversity” lab environment. The exercise was designed to demonstrate a complete, structured penetration-testing workflow, covering reconnaissance, scanning, service enumeration, web application enumeration, vulnerability identification, exploitation, initial access, post-exploitation, privilege escalation assessment, evidence collection, risk assessment, and remediation recommendations.

The objective of the assessment was to demonstrate a structured penetration-testing methodology against an authorised training environment, rather than to attack any production or third-party system.

The practical evidence gathered during this exercise demonstrates the following:

- Network and service discovery performed using Nmap.
- Identification of FTP, SSH, NetBIOS/SMB, Squid proxy, and HTTP services on the target.
- Enumeration of the web server exposed on the target machine.
- Directory discovery performed using Gobuster.
- Identification and testing of an acceptable file-upload extension on the vulnerable web application.
- Successful acquisition of a reverse shell as the www-data user.
- Retrieval of the user-level flag (user.txt).
- Completion of the TryHackMe Vulniversity learning room at 100 percent.

No evidence of root-level compromise was captured during this exercise; therefore this report does not claim privilege escalation to root and restricts privilege escalation discussion to methodology and assessment only.

2. Objectives

- Perform reconnaissance against the authorised lab target.
- Identify exposed network services and versions.
- Enumerate web services and directories.
- Identify potential attack vectors.
- Demonstrate controlled exploitation of the vulnerable web application.
- Obtain initial access to the target.
- Perform post-exploitation enumeration.
- Assess privilege escalation opportunities.
- Collect evidence of successful compromise.
- Document findings and provide remediation recommendations.
- Demonstrate professional penetration-testing reporting.

3. Scope and Authorization

This assessment was performed exclusively against the authorised TryHackMe Vulniversity training environment. No systems outside the scope of this authorised lab were accessed or tested.

Target: TryHackMe Vulniversity

Environment: Intentionally vulnerable cybersecurity training laboratory.

Scope: Network services and the web application exposed by the Vulnversity machine.

Methodology: Reconnaissance → Scanning → Enumeration → Vulnerability Identification → Exploitation → Post-Exploitation → Privilege Escalation Assessment → Reporting

All activity documented in this report was conducted strictly for educational and authorised cybersecurity training purposes within the TryHackMe platform.

Note on target IP addressing: TryHackMe lab instances are provisioned dynamically and may be assigned different IP addresses across separate sessions. The Nmap evidence captured for this exercise shows the target at **10.10.55.159**, while the Gobuster and shell-access evidence, captured in a later session, shows the target at **10.10.109.122**. Both addresses refer to instances of the same TryHackMe Vulnversity lab machine, deployed on different occasions; they are not claimed to have been the same live target simultaneously.

4. Tools Used

Tool	Purpose
Nmap	Network and service discovery
Gobuster	Web directory enumeration
Burp Suite	Web request / file-extension testing
Netcat	Receiving the reverse shell
Linux command line	Post-exploitation enumeration
TryHackMe	Authorised vulnerable lab environment

5. Methodology

Phase 1 – Reconnaissance: Identify the target and gather initial information.

Phase 2 – Scanning: Perform port scanning and service/version detection.

Phase 3 – Enumeration: Enumerate discovered services, web applications, directories, and technologies.

Phase 4 – Vulnerability Identification: Identify weaknesses based on exposed services and application behaviour.

Phase 5 – Exploitation: Demonstrate controlled exploitation of the identified web upload weakness.

Phase 6 – Initial Access: Obtain a shell on the vulnerable machine.

Phase 7 – Post-Exploitation: Identify the current user and locate the user flag.

Phase 8 – Privilege Escalation Assessment: Assess the environment for opportunities to elevate privileges. Only report successful privilege escalation if supported by evidence.

Phase 9 – Reporting: Document findings, evidence, severity, impact, and remediation.

6. Reconnaissance and Network Scanning

Nmap was used to identify open ports, running services, service versions, and other network characteristics of the target lab machine. A SYN stealth scan with service and version detection was performed against the target at 10.10.55.159.

```
SYN Stealth Scan Timing: About 90.21% done; ETC: 20:43 (0:08:04 remaining)
Nmap scan report for ip-10-10-55-159.eu-west-1.compute.internal (10.10.55.159)
Host is up (0.00057s latency).
Not shown: 65529 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.3
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.7 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 5a:4f:fc:b8:c8:76:1c:b5:85:1c:ac:b2:86:41:1c:5a (RSA)
|   256 ac:9d:ec:44:61:0c:28:85:00:88:e9:68:e9:d0:cb:3d (ECDSA)
|_  256 30:50:cb:70:5a:86:57:22:cb:52:d9:36:34:dc:a5:58 (EdDSA)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
3128/tcp  open  http-proxy   Squid http proxy 3.5.12
|_ http-server-header: squid/3.5.12
|_ http-title: ERROR: The requested URL could not be retrieved
3333/tcp  open  http         Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Vuln University
MAC Address: 02:AF:FC:B3:4B:6B (Unknown)
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3.13
OS details: Linux 3.13
Network Distance: 1 hop
Service Info: Host: VULNUNIVERSITY; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Figure 1 – Nmap service and port discovery against the Vulniversity lab target (10.10.55.159).

The evidence identifies the following services:

Port	Service	Version
21/tcp	FTP	vsftpd 3.0.3
22/tcp	SSH	OpenSSH 7.2p2 Ubuntu 4ubuntu2.7
139/tcp	NetBIOS-SSN	Samba
445/tcp	Microsoft-DS / SMB	Samba smbd 4.3.11-Ubuntu
3128/tcp	HTTP proxy	Squid proxy 3.5.12
3333/tcp	HTTP	Apache httpd 2.4.18 (Ubuntu)

The Nmap output also identifies Linux/Unix host characteristics and reports the hostname VULNUNIVERSITY. This reconnaissance phase provided the initial service map used to guide subsequent enumeration; it does not by itself indicate that every detected service was subsequently exploited.

7. Service Enumeration

Nmap script (NSE) scanning was used to gather further detail on the SMB and NetBIOS services identified during the initial scan.

```

Host script results:
|_clock-skew: mean: -1s, deviation: 0s, median: -1s
|_nbstat: NetBIOS name: VULNUNIVERSITY, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: vulnuniversity
|   NetBIOS computer name: VULNUNIVERSITY\x00
|   Domain name: \x00
|   FQDN: vulnuniversity
|_ System time: 2022-07-17T15:51:13-04:00
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_smb2-security-mode:
|   2.02:
|_   Message signing enabled but not required
|_smb2-time:
|   date: 2022-07-17 20:51:13
|_ start_date: 1600-12-31 23:58:45

TRACEROUTE
HOP RTT ADDRESS
1 0.57 ms ip-10-10-55-159.eu-west-1.compute.internal (10.10.55.159)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5416.07 seconds

```

Figure 2 – Nmap NSE/service enumeration results.

The following information was disclosed:

- NetBIOS name: VULNUNIVERSITY
- Workgroup: WORKGROUP
- Samba service information: Samba 4.3.11-Ubuntu, reported OS Windows 6.1 (Samba)
- SMB security mode: account_used = guest, authentication_level = user, challenge_response = supported
- Message signing: disabled (dangerous, but default) for SMBv1; SMBv2 message signing enabled but not required
- Operating-system information reported by Nmap consistent with a Linux 3.x host

This service enumeration phase helps identify possible attack surfaces and configuration weaknesses, particularly around SMB authentication and message-signing configuration. No evidence in this report indicates that the SMB service itself was successfully exploited; it is documented here as part of the enumeration methodology and information-disclosure findings.

8. Web Application Enumeration

The HTTP service identified on port 3333 was confirmed, via the Nmap banner grab shown in Figure 1, as Apache HTTP Server 2.4.18 running on Ubuntu. Following this identification, the web application hosted on this port was examined for hidden functionality and file-upload behaviour, which was then tested further through directory enumeration and file-extension testing as described in the following sections.

9. Directory Enumeration Using Gobuster

Gobuster was used to enumerate hidden directories on the web server running on port 3333 of the target (10.10.109.122 in this evidence capture), using the directory-list-2.3-medium.txt wordlist.

```

root@ip-10-10-245-148:~# gobuster dir -u http://10.10.109.122:3333 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.0.1
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@_FireFart_)
=====
[+] Url:             http://10.10.109.122:3333
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Status codes:     200,204,301,302,307,401,403
[+] User Agent:       gobuster/3.0.1
[+] Timeout:         10s
=====
2022/07/18 09:21:09 Starting gobuster
=====
/images (Status: 301)
/css (Status: 301)
/js (Status: 301)
/fonts (Status: 301)
/internal (Status: 301)
/server-status (Status: 403)
=====
2022/07/18 09:21:30 Finished
=====

```

Figure 3 – Gobuster directory enumeration results against <http://10.10.109.122:3333>.

The following results were returned:

Path	HTTP Status
/images	301
/css	301
/js	301
/fonts	301
/internal	301
/server-status	403

The `/internal` directory was particularly relevant, as directory enumeration exposed additional application functionality beyond the standard static-asset directories. No additional directories or files beyond those shown above were identified during this enumeration.

10. File Upload Functionality and Extension Testing

Using Burp Suite, the file-upload functionality discovered within the /internal application path was tested with multiple file extensions to determine how the server handled different upload types.

Request ^	Payload	Status	Error	Timeout	Length	Comment
0		200	☐	☐	737	
1	.php	200	☐	☐	737	
2	.php3	200	☐	☐	737	
3	.php4	200	☐	☐	737	
4	.php5	200	☐	☐	737	
5	.phtml	200	☐	☐	723	

Request	Response
	<pre>13 <html> 14 <body> 15 <div> 16 <div> 17 <div> 18 <div> 19 <div> 20 <div> 21 <div> 22 <div> 23 <div> 24 <div> 25 </div> 26 </div> 27 <div> 28 <div> 29 <div> 30 <div> 31 <div> 32 <div> 33 <div> 34 </div> 35 </div></pre>

Figure 4 – Testing acceptable file extensions in the web application (Burp Suite).

The evidence shows requests submitted for the following extensions:

- .php
- .php3
- .php4
- .php5
- .phtml

All five requests returned an HTTP 200 response, with the .phtml request producing a shorter response length (723 bytes) than the four .php variants (737 bytes each), and the response body captured in the evidence includes a highlighted “Success” message. This testing demonstrated a measurable difference in server response and was used to identify an extension accepted by the vulnerable upload functionality. The exact underlying server-side validation logic is not visible in the evidence and is therefore not described beyond what is shown.

11. Initial Exploitation

Based on the results of the extension testing described above, the vulnerable web application permitted an attacker to upload executable server-side content through the identified upload functionality. This represents an unrestricted or insufficiently restricted file-upload vulnerability, in which server-side executable content can be

uploaded and subsequently executed by the web server.

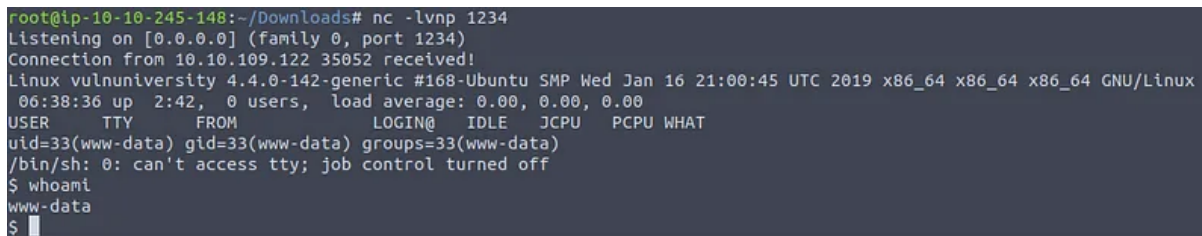
The security impact of this class of vulnerability includes:

- Arbitrary server-side code execution.
- Potential remote command execution.
- Potential compromise of the web-server service account.
- Potential access to sensitive files accessible to the web-server process.
- Possible escalation to higher privileges, depending on local system configuration.

No claim of root-level access is made at this stage of the assessment.

12. Initial Access / Reverse Shell

Following exploitation of the file-upload vulnerability, a Netcat listener was used to capture an incoming reverse shell connection from the target.



```
root@ip-10-10-245-148:~/Downloads# nc -lvnp 1234
Listening on [0.0.0.0] (family 0, port 1234)
Connection from 10.10.109.122 35052 received!
Linux vulniversity 4.4.0-142-generic #168-Ubuntu SMP Wed Jan 16 21:00:45 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux
06:38:36 up 2:42, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$
```

Figure 5 – Successful shell connection to the Vulniversity target (10.10.109.122).

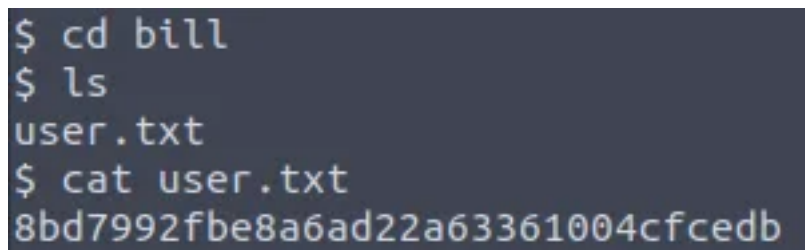
The evidence confirms that a connection was received through Netcat from the target host 10.10.109.122. The shell identified the current user as **www-data**, with the terminal output showing uid=33(www-data) gid=33(www-data) groups=33(www-data), and reporting the host as running Ubuntu Linux (kernel 4.4.0-142-generic). This confirms successful initial access to the target with web-server-level privileges.

13. Post-Exploitation Enumeration

After obtaining shell access, basic post-exploitation enumeration was performed. The objective of this phase was to identify the current account, accessible directories, sensitive files, and potential privilege-escalation paths available from the www-data context. Enumeration activity beyond identifying the current user and locating the user flag, described in the following section, is not documented here, as it is not supported by the supplied evidence.

14. User Flag

The established shell session was used to navigate to the home directory of the local user **bill**, where the user flag file was located and read.



```
$ cd bill
$ ls
user.txt
$ cat user.txt
8bd7992fbe8a6ad22a63361004cfcedb
```

Figure 6 – Retrieval of the Vulniversity user flag.

The evidence shows the directory listing containing user.txt within the bill user's directory, and the contents of the flag as read via the cat command: **8bd7992fbe8a6ad22a63361004cfcedb**. Retrieval of this flag demonstrates successful compromise of the target at the user-level stage.

15. Privilege Escalation Assessment

Privilege escalation assessment was considered as part of the capstone methodology. The purpose of this phase, in general penetration-testing practice, is to:

- Identify SUID binaries.
- Review writable files and directories.
- Check scheduled tasks (cron jobs).
- Review sudo permissions available to the current user.
- Identify weak service or file configurations.
- Search for exploitable local services or kernel vulnerabilities.
- Assess opportunities to move from a low-privileged account to root.

Evidence status: the supplied evidence set establishes successful user-level access and user-flag retrieval, as documented in Sections 12 and 14. No screenshot demonstrating a root shell, root flag, SUID enumeration result, or successful privilege escalation was included in the evidence set for this exercise. Accordingly, this report does not claim that root-level compromise was achieved, and privilege escalation is documented here at the methodology and assessment level only.

16. Vulnerability Findings

Finding 1: Unrestricted / Insufficiently Restricted File Upload – Severity: High

Evidence: The web application accepted an executable server-side file extension through its upload functionality, followed by successful shell access as www-data.

Impact: An attacker may execute arbitrary commands on the web server under the web-server account.

Remediation:

- Allow-list safe file extensions.
- Validate MIME types and file signatures.
- Rename uploaded files.
- Store uploads outside the web root.
- Disable script execution in upload directories.
- Apply server-side validation.
- Reject executable extensions.
- Use least-privilege permissions.
- Implement antivirus / content inspection where appropriate.

Finding 2: Exposed Network Services – Severity: Medium

Evidence: Nmap identified multiple exposed services, including FTP, SSH, NetBIOS/SMB, Squid, and HTTP.

Impact: A large exposed attack surface increases opportunities for service-specific attacks and information disclosure.

Remediation:

- Disable unnecessary services.
- Restrict access using firewall rules.
- Segment services.
- Apply current security patches.
- Restrict management interfaces.
- Use strong authentication.

Finding 3: Information Disclosure Through Service Enumeration – Severity: Low/Medium

Evidence: Service/version information and SMB/NetBIOS information were disclosed during enumeration.

Impact: Detailed service information can assist attackers in identifying potential vulnerabilities and attack paths.

Remediation:

- Minimise unnecessary service banners.
- Restrict SMB exposure.
- Disable unnecessary NetBIOS services.
- Keep systems patched.
- Use network segmentation.

- Monitor reconnaissance activity.

17. Risk Assessment

Finding	Severity	Evidence	Potential Impact
Unrestricted/Insufficiently Restricted File Upload	High	Upload testing + successful shell	Remote code execution / server compromise
Exposed Network Services	Medium	Nmap scan	Increased attack surface
Service/Network Information Disclosure	Low/Medium	Nmap enumeration	Information gathering assistance

Severity ratings above are based on the demonstrated technical impact observed within the authorised lab environment.

18. Evidence Summary

Figure	Description
Figure 1	Nmap service and port discovery
Figure 2	Nmap service/NSE enumeration
Figure 3	Gobuster directory enumeration
Figure 4	File-extension testing
Figure 5	Successful shell connection
Figure 6	User flag retrieval
Figure 7	TryHackMe Vulniversity room completion
Figure 8	TryHackMe Basic Pentesting room completion

19. TryHackMe Vulnversity Room Completion

The following screenshot demonstrates completion of the Vulnversity learning room on the TryHackMe platform.

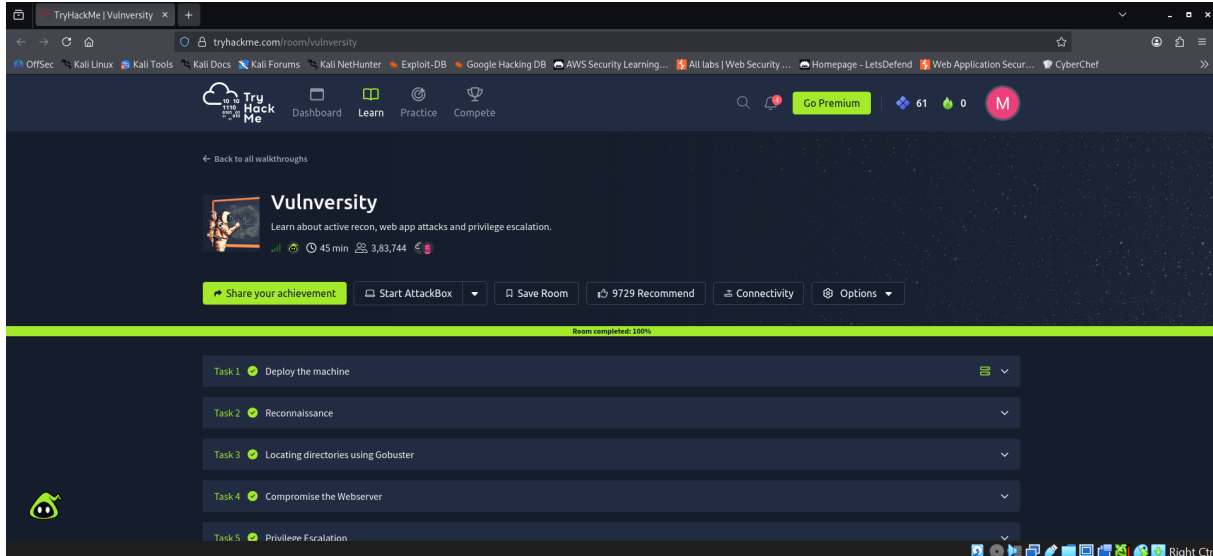


Figure 7 – TryHackMe Vulnversity room completed at 100 percent.

The following screenshot demonstrates completion of an additional penetration-testing practice room, “Basic Pentesting,” covering web application security and privilege escalation concepts.

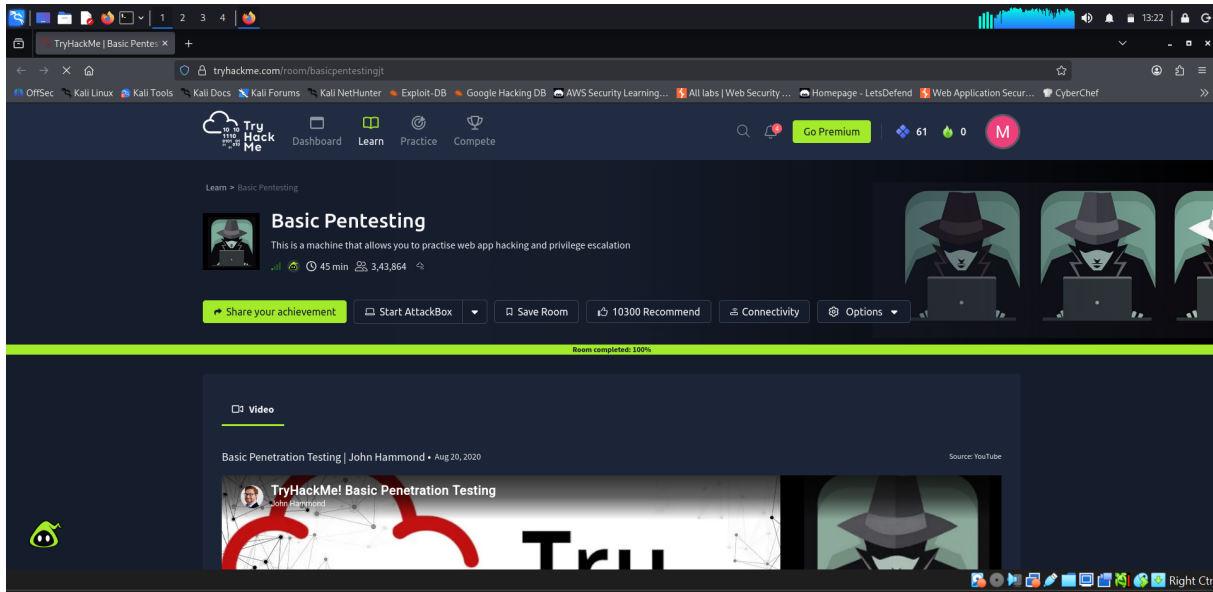


Figure 8 – TryHackMe Basic Pentesting room completed at 100 percent.

Detailed exploitation steps and individual challenge answers for the Basic Pentesting room are not documented in this report, as corresponding detailed evidence was not supplied for that room; the completion screenshot is included solely as evidence that the room was completed.

20. Remediation Plan

Web File Upload

- Implement strict extension allow-listing.

- Validate uploaded files server-side.
- Validate MIME type and file signatures.
- Rename uploaded files.
- Store uploads outside the web-accessible directory.
- Disable execution permissions in upload directories.
- Apply least privilege.

Network Services

- Disable unnecessary services.
- Restrict FTP, SMB, proxy, and administrative services.
- Apply firewall rules.
- Segment network services.
- Patch outdated software.

Web Server

- Keep Apache and operating system packages updated.
- Remove unnecessary applications.
- Apply secure configuration.
- Restrict access to sensitive directories.

Monitoring

- Monitor suspicious upload activity.
- Monitor unusual web-server processes.
- Monitor outbound connections.
- Centralise security logs.
- Configure alerts for suspicious command execution.

21. Security Best Practices

- Principle of least privilege.
- Network segmentation.
- Secure file-upload handling.
- Regular vulnerability scanning.
- Patch management.
- Secure configuration.
- Centralised logging.
- Continuous monitoring.
- Periodic penetration testing.

- Security awareness.

22. Conclusion

This capstone exercise demonstrated a structured penetration-testing process against an authorised, intentionally vulnerable training environment. The demonstrated attack chain proceeded as follows:

Reconnaissance → Port and Service Discovery → Web Enumeration → Directory Discovery → File Upload Testing → Exploitation → Web-Server Shell → User-Level Access → User Flag Retrieval

The exercise demonstrated how a web application weakness, specifically insufficient restriction of uploaded file types, can lead to server compromise at the web-service-account level. It underscores why secure file-upload controls, service hardening, least-privilege configuration, and continuous monitoring are important defensive measures for production environments. No root-level compromise was achieved or claimed as part of this exercise.

23. References

- TryHackMe – Vulniversity – <https://tryhackme.com/room/vulniversity>
- TryHackMe – Basic Pentesting – <https://tryhackme.com/room/basicpentestingjt>
- Nmap Documentation – <https://nmap.org/book/man.html>
- Gobuster Documentation – <https://github.com/OJ/gobuster>
- Burp Suite Documentation – <https://portswigger.net/burp/documentation>
- OWASP Web Security Testing Guide – <https://owasp.org/www-project-web-security-testing-guide/>
- OWASP File Upload Cheat Sheet – https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html